

FUTURE INTERNS | CYBER SECURITY TASK 1

Vulnerability Assessment Report

Altoro Mutual Demonstration Website

TARGET	https://demo.testfire.net/
ASSESSMENT TYPE	Read-only, unauthenticated vulnerability assessment
ASSESSOR	R Aniruthvishwak
ASSESSMENT DATE	31 August 2026
ENVIRONMENT	Kali Linux virtual machine on VMware Fusion
CLASSIFICATION	Educational / Public demonstration target

OVERALL RISK HIGH - The public login workflow can submit credentials over unencrypted HTTP.

ETHICAL SCOPE

Testing was limited to public pages, basic web-port exposure, response-header inspection, TLS certificate review and OWASP ZAP passive analysis. No credentials, payloads, exploitation, brute force, active scanning or denial-of-service activity were used.

1. Executive Summary

A read-only security review of the Altoro Mutual demonstration application identified one confirmed High-risk weakness, three confirmed Medium-risk weaknesses, one potential Medium-risk issue with low confidence, and three confirmed Low-risk weaknesses. The assessment combined manual verification with passive automated analysis; tool severity was not accepted without review.

PRIORITY ACTION Enforce HTTPS across the entire application, redirect all HTTP requests, renew the expired certificate, and prevent authentication forms from operating over cleartext connections.

Business Risk at a Glance

Category	Count	Meaning
High	1	Immediate action: sensitive authentication data may traverse HTTP.
Medium	3	Confirmed transport and browser-hardening weaknesses.
Medium	1	Anti-CSRF alert requires authorised authenticated verification.
Low	3	Defence-in-depth and information-disclosure weaknesses.

Key Conclusions

- The HTTP login page returns 200 OK instead of redirecting to HTTPS.
- The login form uses a relative POST action, so credentials can be submitted over HTTP when the insecure page is used.
- The TLS certificate expired on 21 June 2026, causing normal clients to reject the HTTPS connection.
- Passive analysis corroborated missing CSP, anti-clickjacking, SameSite and MIME-sniffing protections.
- No exploitation was required to establish the confirmed findings.

2. Scope, Ethics and Methodology

Assessment Objective

Identify publicly observable security weaknesses, explain their business impact, assign proportionate risk ratings and recommend practical remediation while preserving a strict read-only boundary.

In Scope	Out of Scope
• Public pages • Normal navigation • Headers and cookies • Ports 80 and 443 • TLS certificate • ZAP passive alerts	• Exploit payloads • Authentication bypass • Brute force • Directory enumeration • ZAP Active Scan • Data modification or DoS

Methodology

1. Define scope and confirm the target is an intentionally vulnerable HCL demonstration application.
2. Review public pages and record the application context without submitting forms.
3. Check only ports 80 and 443 with Nmap and distinguish expected exposure from vulnerabilities.
4. Inspect HTTP/HTTPS responses, cookies, login-form behaviour and certificate dates with curl and OpenSSL.
5. Proxy normal browsing through OWASP ZAP in Safe Mode and collect passive alerts only.
6. Manually validate alerts, classify confidence, redact session values and document remediation.

Tools Used

Nmap 7.99	Limited exposure check of TCP ports 80 and 443.
curl	HTTP status, redirection, response headers and cookie attributes.
OpenSSL	Certificate subject, issuer and validity dates.
OWASP ZAP 2.17.0	Safe Mode proxying and passive alert analysis.

Firefox	Public-page review and normal navigation.
Kali Linux	Isolated assessment environment in VMware Fusion.

3. Target Overview and Exposure

Altoro Mutual is the AltoroJ demonstration banking application maintained by HCL Software for security-product testing. It is not a real bank. The review treated the site as an external, unauthenticated public application and did not rely on its intended vulnerability status to inflate findings.

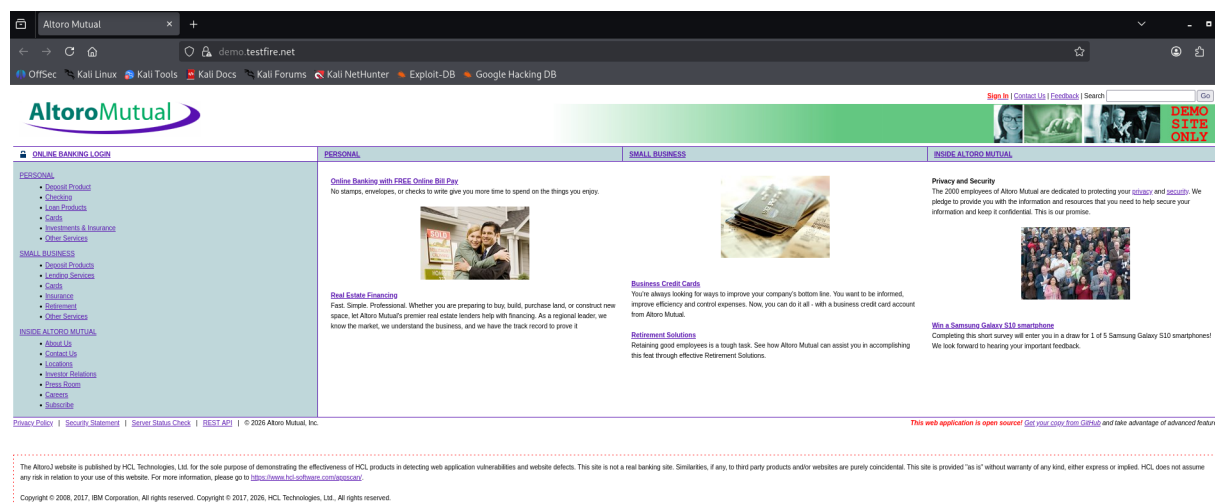


Figure 1. Altoro Mutual demonstration website assessed under a read-only scope.

Limited Network Exposure

A narrow Nmap check confirmed that TCP ports 80 and 443 were open. This is expected for a public web application and is recorded as an informational observation, not a vulnerability. The security concern is the application behaviour on port 80, addressed under F-01.

```
(kali@kali)-[~/FutureInterns/Task1]
$ nmap -Pn -p 80,443 --reason demo.testfire.net -oN evidence/nmap/04_nmap_web_ports.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-30 13:41 -0400
Nmap scan report for demo.testfire.net (65.61.137.117)
Host is up, received user-set (0.26s latency).

PORT      STATE SERVICE REASON
80/tcp    open  http   syn-ack ttl 128
443/tcp   open  https  syn-ack ttl 128

Nmap done: 1 IP address (1 host up) scanned in 5.83 seconds
```

Figure 2. Limited Nmap check confirming HTTP and HTTPS exposure on ports 80 and 443.

4. Findings Summary

Risk reflects likelihood and potential business impact. “Potential” indicates that the evidence is insufficient to confirm exploitability within the authorised read-only scope.

ID	Finding	Risk	Status
F-01	Login credentials can be submitted over unencrypted HTTP	High	Confirmed
F-02	Expired TLS certificate	Medium	Confirmed
F-03	Content Security Policy header missing	Medium	Confirmed
F-04	Anti-clickjacking header missing	Medium	Confirmed
F-05	Anti-CSRF tokens not identified	Medium	Potential / Low confidence
F-06	Session cookie missing SameSite attribute	Low	Confirmed
F-07	X-Content-Type-Options header missing	Low	Confirmed
F-08	Server technology information disclosed	Low	Confirmed
O-01	HTTP and HTTPS ports exposed	Info	Observed

Risk Interpretation

High	Immediate remediation: credible exposure of sensitive data or major account impact.
Medium	Material weakness requiring planned remediation and verification.
Low	Defence-in-depth weakness with narrower direct impact.
Info	Expected exposure or contextual observation; not a vulnerability by itself.

F-01 Login Credentials Can Be Submitted Over Unencrypted HTTP

High

Status: Confirmed
Classification: Read-only assessment

Evidence: Verified manually

Observation

The HTTP login page returned 200 OK rather than redirecting to HTTPS. Its login form uses a relative POST action (`doLogin`). When a user accesses the page over HTTP, the browser submits the username and password through the same unencrypted origin.

Redacted HTTP evidence

HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Set-Cookie: JSESSIONID=[REDACTED]; Path=/; HttpOnly
Content-Type: text/html; charset=ISO-8859-1
Transfer-Encoding: chunked
Date: Mon, 31 Aug 2026 04:17:11 GMT

URL: http://demo.testfire.net/login.jsp
Status: 200
Redirect:
Content-Type: text/html; charset=ISO-8859-1

```
(kali@kali)-[~/FutureInterns/Task1]
$ curl -sS http://demo.testfire.net/login.jsp -o evidence/devtools/08_http_login_page.html
(kali@kali)-[~/FutureInterns/Task1]
$ grep -inE '<form|password' evidence/devtools/08_http_login_page.html
23: <form id="frmSearch" method="get" action="/search.jsp">
102: <form action="doLogin" method="post" name="login" id="login" onsubmit="return (confirminput(login));">
116:   Password:
119:   <input type="password" id="passw" name="passw" style="width: 150px;">
152:   alert ("You must enter a valid password");
```

Figure 3. Public login-page source showing a relative POST action and password input field.

Business Impact

A network-positioned attacker could intercept usernames, passwords or session information. In a real banking environment, this could lead to account takeover, unauthorised transactions, privacy violations, regulatory exposure and loss of customer trust.

Recommended Remediation

- Redirect every HTTP request to HTTPS using a permanent 301 or 308 response.
- Serve authentication pages only over HTTPS and use explicit HTTPS form actions.
- Enable HSTS after validating that all application content supports HTTPS.
- Set Secure, HttpOnly and an appropriate SameSite value on every session cookie.
- Test the final configuration to confirm that credentials can never traverse HTTP.

F-02 Expired TLS Certificate

Medium**Status:**

Confirmed

Classification: Read-only assessment**Evidence:** Verified manually

Observation

The TLS certificate for `demo.testfire.net` expired on 21 June 2026. The assessment occurred on 31 August 2026. Normal curl validation failed and Firefox displayed a certificate warning; OpenSSL independently confirmed the validity dates.

```
(kali@kali)-[~/FutureInterns/Task1]
$ openssl s_client -connect demo.testfire.net:443 -servername demo.testfire.net </dev/null 2>/dev/null | openssl x509 -noout -subject -issuer -dates | tee
evidence/devtools/07_tls_certificate_details.txt
subject=CN=demo.testfire.net
issuer=C=GB, ST=Greater Manchester, L=Salford, O=Sectigo Limited, CN=Sectigo RSA Domain Validation Secure Server CA
notBefore=May 21 00:00:00 2025 GMT
notAfter=Jun 21 23:59:59 2026 GMT
```

Figure 4. OpenSSL certificate inspection confirming expiry on 21 June 2026.

Business Impact

Users cannot establish a normally trusted HTTPS connection. Certificate warnings may cause abandonment, encourage unsafe warning bypasses and make legitimate service identity harder to distinguish from interception attempts.

Recommended Remediation

- Renew and deploy a valid certificate with the complete trust chain.
- Automate renewal and alert well before expiration.
- Monitor certificate validity externally and include expiry in operational checks.
- Retest HTTPS validation after deployment across common browsers and clients.

IMPORTANT An expired certificate does not prove interception. It means browsers can no longer validate the site identity normally.

F-03 Content Security Policy Header Missing

Medium

Status:

Confirmed

Classification: Read-only assessment

Evidence: Verified

manually

The HTTPS response did not include a Content-Security-Policy header. ZAP passive analysis independently reported the same condition. CSP is a defence-in-depth control that limits the browser resources allowed to execute or load.

Business Impact and Remediation

If another injection flaw exists, the absence of CSP can increase browser-side impact. Deploy a restrictive policy, begin with `Content-Security-Policy-Report-Only`, allow resources only from trusted sources, and avoid `unsafe-inline` or `unsafe-eval` wherever feasible.

F-04 Anti-Clickjacking Header Missing

Medium

Status:

Confirmed

Classification: Read-only assessment

Evidence: Verified

manually

Responses lacked `X-Frame-Options` and no CSP `frame-ancestors` directive was observed. The site may therefore be embeddable in a hostile frame. No clickjacking proof-of-concept was attempted.

Business Impact and Remediation

A deceptive parent page could overlay content and trick users into unintended clicks. Prefer `Content-Security-Policy: frame-ancestors 'self'` and retain `X-Frame-Options: SAMEORIGIN` for legacy compatibility, or use `DENY` if framing is never required.

- ▼ 📁 Alerts (9)
 - > 📁 Absence of Anti-CSRF Tokens (2)
 - > 📁 Content Security Policy (CSP) Header Not Set (4)
 - > 📁 Missing Anti-clickjacking Header (4)
 - > 📁 Cookie without SameSite Attribute
 - > 📁 Server Leaks Version Information via "Server" HTTP Response Header Field (5)
 - > 📁 X-Content-Type-Options Header Missing (5)
 - > 📁 Information Disclosure - Suspicious Comments
 - > 📁 Modern Web Application
 - > 📁 Session Management Response Identified (2)

Figure 5. OWASP ZAP passive alert summary corroborating missing browser-security headers.

F-05 Anti-CSRF Tokens Not Identified

Medium

Status:

Potential /

Low

confidence

Classification: Read-only assessment

Evidence: Verified

manually

Observation

ZAP passively observed two HTML submission forms without a recognised anti-CSRF token and rated the issue Medium risk with Low confidence. Passive inspection cannot prove that a meaningful cross-site request forgery attack is possible.

The screenshot shows the 'Edit Alert' window in OWASP ZAP. The alert is titled 'Absence of Anti-CSRF Tokens'. The URL is 'http://demo.testfire.net/login.jsp'. The risk is set to 'Medium' and the confidence is 'Low'. The parameter is empty. The attack field is empty. The evidence is ':"return (confirminput(login));">'. The CWE ID is '352' and the WASC ID is '9'. The description states: 'No Anti-CSRF tokens were found in a HTML submission form. A cross-site request forgery is an attack that involves forcing a victim to send an'. The other info field lists various tokens that were not found: 'No known Anti-CSRF token [anticsrf, CSRFToken, __RequestVerificationToken, csrfmiddlewaretoken, authenticity_token, OWASP_CSRFTOKEN, anoncsrf]'. The solution field says: 'Phase: Architecture and Design Use a vetted library or framework that'. The window has 'Cancel' and 'Save' buttons at the bottom.

Figure 6. ZAP passive anti-CSRF alert for the login page, explicitly marked Low confidence.

Business Impact

If sensitive state-changing requests do not validate anti-CSRF tokens, an attacker may be able to cause an authenticated user to perform an unintended action. The actual impact depends on authenticated behaviour that was outside scope.

Recommended Remediation

- Issue unpredictable anti-CSRF tokens and validate them server-side for state-changing operations.
- Use an appropriate SameSite cookie policy and verify Origin or Referer as additional controls.
- Perform separately authorised authenticated testing before upgrading this issue to confirmed.

SCOPE LIMITATION No authenticated actions or CSRF exploitation were performed. This finding must remain potential, not confirmed.

5. Low-Risk Findings

Redacted HTTPS response headers

```
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Set-Cookie: JSESSIONID=[REDACTED]; Path=/; Secure; HttpOnly
Content-Type: text/html;charset=ISO-8859-1
Transfer-Encoding: chunked
Date: Mon, 31 Aug 2026 04:15:33 GMT
```

F-06

Session Cookie Missing SameSite Attribute

LOW

Observation: The HTTPS 'JSESSIONID' cookie included Secure and HttpOnly but no explicit SameSite value.

Remediation: Set 'SameSite=Lax' or 'SameSite=Strict' unless cross-site use is required; use 'SameSite=None; Secure' only when necessary.

F-07

X-Content-Type-Options Header Missing

LOW**Observation:** Responses did not include `X-Content-Type-Options: nosniff`.**Remediation:** Add `X-Content-Type-Options: nosniff` and return accurate Content-Type values for every resource.**F-08****Server Technology Information Disclosed****LOW****Observation:** Responses disclosed `Server: Apache-Coyote/1.1`.**Remediation:** Minimise the Server header, avoid precise version disclosure, maintain patching and use generic error pages.

6. Prioritised Remediation Roadmap

The recommended sequence addresses the highest exposure first, then strengthens browser-side defences and operational hygiene.

Priority	Timeframe	Action	Validation
P0	Immediate	Renew TLS certificate; force HTTP-to-HTTPS redirects; disable cleartext login.	HTTP returns 301/308; browsers trust HTTPS; login never posts to HTTP.
P1	0-7 days	Deploy HSTS and secure cookie attributes after full HTTPS validation.	HSTS present; Secure, HttpOnly and SameSite visible on session cookies.
P2	1-2 weeks	Implement CSP, frame-ancestors/X-Frame-Options and nosniff.	Headers present on representative pages; CSP report-only findings reviewed.
P3	2-4 weeks	Review anti-CSRF design and minimise server disclosure.	Authorised authenticated review passes; Server header is generic or removed.

Retest Acceptance Criteria

- Every HTTP path redirects to the equivalent HTTPS path without serving application content.
- The TLS chain validates without warnings and monitoring covers future expiration.
- The login form cannot render or submit over HTTP.
- CSP, frame protection and nosniff are present on representative responses.
- Session cookies include Secure, HttpOnly and an intentional SameSite policy.
- Any anti-CSRF conclusion is based on authorised authenticated testing rather than passive inference.

7. Limitations and Conclusion

Assessment Limitations

- Unauthenticated public pages only; no user account or business transaction was tested.
- No active vulnerability scan, exploit payload, brute force, forced browsing or denial-of-service activity.
- No source-code review, dependency inventory or server-side configuration access.
- Findings reflect the observable state on 31 August 2026 and may change after configuration updates.
- The anti-CSRF observation remains potential because authenticated state changes were outside scope.

Conclusion

The review found a clear and actionable transport-security failure: the banking-style login workflow can operate over HTTP and submit credentials without encryption. Combined with an expired certificate, this creates a poor trust boundary for users and warrants immediate remediation. The remaining confirmed issues concern browser hardening, cookie policy and information disclosure. They are lower impact individually but should be resolved as part of a consistent secure-response baseline.

The assessment deliberately separated observations from vulnerabilities, and potential findings from confirmed weaknesses. Open web ports were not mislabelled as vulnerabilities, and the CSRF alert was retained at low confidence because the read-only scope did not permit authenticated validation.

FINAL VERDICT Overall risk: HIGH until HTTP authentication is eliminated and trusted HTTPS is

restored.

Evidence Handling

Supporting files include the limited Nmap output, redacted HTTP headers, TLS certificate details, login-form source, ZAP passive screenshots and a target-only HTML report. The two original header screenshots were excluded from this report because they retained temporary session-cookie values; redacted text evidence was used instead.

8. References

- **HCL Altoro Mutual demonstration application:** <https://demo.testfire.net/>
- **HCL Software - Demo websites for AppScan testing:** https://support.hcl-software.com/csm?id=kb_article&sysparm_article=KB0010981
- **OWASP ZAP Passive Scanner:** <https://www.zaproxy.org/docs/desktop/addons/passive-scanner/>
- **OWASP ZAP Alert Details:** <https://www.zaproxy.org/docs/alerts/>
- **Nmap - Legal Issues:** <https://nmap.org/book/legal-issues.html>
- **OWASP Transport Layer Security Cheat Sheet:** https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Security_Cheat_Sheet.html
- **CWE-319 - Cleartext Transmission of Sensitive Information:** <https://cwe.mitre.org/data/definitions/319.html>
- **MDN - Strict-Transport-Security:** <https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security>
- **MDN - Content Security Policy:** <https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP>
- **MDN - X-Frame-Options:** <https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options>
- **MDN - X-Content-Type-Options:** <https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options>
- **MDN - Set-Cookie:** <https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Set-Cookie>
- **OWASP Session Management Cheat Sheet:** https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html
- **OWASP CSRF Prevention Cheat Sheet:** https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html
- **CWE-352 - Cross-Site Request Forgery:** <https://cwe.mitre.org/data/definitions/352.html>

References accessed 31 August 2026. All testing and interpretation were performed for defensive educational purposes against the named demonstration target.